Parasoft C/C++test vs SonarQube CLI

ThreadX Win32 flow-analysis benchmark | 2026-10-08

Bottom line: Parasoft Flow Analysis Aggressive matched 15 of 50 valid planted defects. SonarQube CLI code analysis was unavailable: the connection lacks Vortex entitlement, so the endpoint returned 403 Forbidden and skipped all source files.

Profile	XML findings (clean vs bugged)	Harness findings (clean vs bugged)	Valid candidate score	Strict false negatives	Interpretation
Parasoft Flow Analysis Aggressive	90 vs 111	6 vs 27	15 TP, 1 partial, 1 indirect / 50	35	Full scans completed; includes 84 upstream findings per state.
Parasoft Recommended Rules	20 vs 36 (+12 metrics each)	5 vs 21	14 TP, 1 indirect / 50	36	Supplementary profile; includes upstream ThreadX findings.
SonarQube CLI DEEP	N/A	N/A	Not scorable	Not scorable	Vortex 403 Forbidden; 8/8 all-file inputs skipped.

Recall by defect family

Family	Valid	Agg TP	Agg partial / indirect	Agg direct FN	Rec TP	Rec direct FN
Size arithmetic	11	2	0	9	2	9
Memory lifecycle	10	3	1 partial	6	2	8
Concurrency	8	0	0	8	0	8
NULL / validation	7	5	1 indirect	1	5	1
Taint / bounds	8	3	0	5	3	5
Uninitialized memory	6	2	0	4	2	4
Total	**50**	**15**	**1 partial, 1 indirect**	**33**	**14**	**35**

Scoring notes

- There are 52 planted markers, but BUG-005 cannot overflow 32-bit ULONG on Win32 and BUG-031's shared guard proves the primary pointer non-NULL. Both are excluded; denominator is 50.
- BUG-021 is a related lost-resource signal and BUG-035 an indirect late-null-check signal; neither is a strict TP, so both count as FNs.
- The clean baseline contains a real unmarked over-read in sa_store_len: it can copy up to 65,535 bytes from sa_src[128]. It is not a planted TP.

Parasoft detection highlights

- Bounds: ring index, raw[64], destination overflow, stale slot bound, and handler-table index.
- Resource lifetime: use-after-free, interior-pointer free, and retry-buffer leaks.
- NULL and initialization: unchecked channel and allocation results, ignored out-parameter errors, uninitialized return/pointer use, deep null dereference, and incomplete header initialization.
- Neither Parasoft profile reported a planted concurrency defect.

SonarQube CLI

Authentication succeeded and the repository was imported into the zuwasi organization as project zuwasi_parasoft-vs-sonarqube-threadx. CLI system status says Vortex is not entitled; Sonar Agent Essentials is a separate subscription. Project-backed DEEP analysis returned 403 Forbidden for both runs and skipped all source files. This is unavailable code analysis, not a zero-issue result. The local secrets scanner reported zero secrets in both states; that result does not score the C defects.

The full per-candidate matrix, normalized findings, audit trail, and limitations are in evaluation/reports/adjudication/DETECTION_MATRIX.csv, evaluation/reports/parasoft/, evaluation/reports/sonarqube/, and evaluation/SCAN_PROTOCOL.md.